

Datenklassifizierung als Fundament der unternehmerischen Resilienz: Eine tiefgehende Analyse von Volumen, Periodizität und Zugriffssicherheit

Basierend auf den Prinzipien und Modellen von Mevluet Polat

1. Einleitung und grundlegende Systematik

In der modernen Informationsgesellschaft bilden Daten das zentrale Fundament jeglicher unternehmerischer Wertschöpfung. Der exponentielle Anstieg von Datenmengen, gepaart mit einer zunehmenden Komplexität der IT-Infrastrukturen und verschärften regulatorischen Anforderungen, zwingt Unternehmen dazu, ihre Informationsbestände nicht länger als homogene Masse zu betrachten. Vielmehr bedarf es einer systematischen und methodisch fundierten Differenzierung. Die Datenklassifizierung, wie sie in den Modellen von Mevluet Polat dargelegt wird, bietet hierfür einen essenziellen theoretischen und praktischen Rahmen. Sie beschreibt die systematische Einteilung von Daten nach spezifischen Kriterien – primär nach Volumen, Periodizität und Zugriffssicherheit – um sie für den Unternehmenseinsatz optimal nutzbar und vor allem sicher zu machen.

Eine fundierte Klassifizierung ist keineswegs ein theoretischer Selbstzweck. Aus den ermittelten Klassifizierungskriterien lassen sich direkt konkrete betriebliche Anforderungen ableiten, insbesondere für kritische Prozesse wie das IT-Service-Continuity-Management und das Design von Backup-Systemen. Die Ergebnisse dieser Klassifizierung müssen zwingend in verbindliche Vorgaben überführt werden, die für sämtliche Akteure und Stakeholder innerhalb einer Organisation Gültigkeit besitzen. Dabei ist zu betonen, dass diese Systematik universell anwendbar sein muss: Sie gilt gleichermassen für hochkomplexe Applikationen, relationale und nicht-relationale Datenbanken, unstrukturierte Dateisysteme und jegliche sonstigen Datenbestände. Ein weiterer zentraler Aspekt ist die Dynamik dieses Prozesses. Klassifizierungen sind per Definition nicht statisch. Sie unterliegen einem stetigen Wandel und müssen bei veränderten technologischen Rahmenbedingungen, neuen geschäftlichen Anforderungen oder der Einführung neuer Datenbestände kontinuierlich evaluiert und angepasst werden.

2. Die Klassifizierung von Applikationen und die Ableitung betrieblicher Anforderungen

Um die Relevanz der Datenklassifizierung in der Praxis zu verstehen, muss zunächst die Applikationsebene betrachtet werden. IT-Systeme existieren nicht im luftleeren Raum, sondern dienen der Unterstützung von Geschäftsprozessen. Die Geschäftskritikalität einer Applikation wird massgeblich danach bewertet, wie stark ein potenzieller Ausfall die Kernprozesse (Core Business Processes) eines Unternehmens beeinträchtigt.

Ein weiterer Faktor ist die Datenabhängigkeit. Applikationen, die über eigene, komplexe Datenbankstrukturen verfügen, erfordern hochgradig abgestimmte Backup-Strategien, um die transaktionale Konsistenz der Daten im Falle einer Wiederherstellung (Restore) sicherzustellen. Auch die Nutzungszeiten spielen eine gravierende Rolle: Ein System, das im 24/7-Betrieb laufen muss, unterliegt fundamental höheren Verfügbarkeitsanforderungen und benötigt entsprechend häufigere und unterbrechungsfreie Datensicherungen als ein System, das nur zu üblichen Bürozeiten genutzt wird. Hinzu kommt die Integrationstiefe. In modernen Microservices- oder SOA-Architekturen (Service-Oriented Architecture) sind Applikationen stark vernetzt. Solche Systeme müssen zwingend gemeinsam und zeitsynchron gesichert werden, um im Disaster-Fall konsistente Wiederherstellungspunkte über alle Systemgrenzen hinweg garantieren zu können.

Aus diesen Parametern wird jeder Applikation eine spezifische Recovery-Klasse zugewiesen. Diese Klasse definiert zwei der wichtigsten Metriken im IT-Notfallmanagement: das Recovery Time Objective (RTO) und das Recovery Point Objective (RPO).

Beispiel zur Applikationsklassifizierung:

Ein Spital betreibt ein elektronisches Patienteninformationssystem (KIS) und ein System zur Verwaltung der Speisepläne für die Cafeteria. Das KIS hat eine extrem hohe Geschäftskritikalität und ist im 24/7-Betrieb (Integrationstiefe mit Labor- und Röntgensystemen). Ein Ausfall gefährdet direkt Menschenleben. Das RTO (wie schnell das System wieder laufen muss) liegt hier bei wenigen Minuten, das RPO (wie viel Datenverlust tolerierbar ist) bei nahezu null Sekunden. Das Speiseplansystem hingegen hat eine geringe Kritikalität. Wenn es ausfällt, entsteht maximal ein logistischer Mehraufwand. Hier könnte ein RTO von 24 Stunden und ein RPO von 24 Stunden (tägliches Backup) völlig ausreichend sein.

Aus all diesen Klassifizierungsparametern wird ein umfassender Anforderungskatalog generiert, der das Rückgrat des Backup-Konzepts bildet. Dieser Katalog ermöglicht eine klare Priorisierung: Systeme mit hoher Kritikalität und sehr kurzem RTO werden sowohl bei der Zuweisung von Speicherressourcen als auch bei der Reihenfolge der Wiederherstellung im Notfall strikt bevorzugt behandelt. Dies erfordert unweigerlich eine betriebswirtschaftliche Kostenabwägung. Kürzere RPO- und RTO-Werte bedingen exponentiell höhere Sicherungskosten, die stets gegen den potenziellen finanziellen und reputativen Schaden eines Datenverlusts abgewogen werden müssen. Letztlich determinieren diese abgeleiteten

Anforderungen die Technologiewahl (z. B. Bandsicherung vs. NVMe-Flash-Storage) und müssen in einer lückenlosen Dokumentation festgehalten werden.

3. Vertiefung: Klassifizierung nach Volumen und Speichereffizienz

Die erste Hauptkategorie der detaillierten Klassifizierung betrifft das Datenvolumen. Die physische Grösse der Daten ist der grundlegendste Parameter für die Auslegung jeder IT-Infrastruktur. Das Gesamtvolumen – also die Summe aller zu sichernden Daten – bestimmt direkt die benötigte Speicherkapazität sowie die Dauer, die für einen vollständigen Backup-Durchlauf benötigt wird (Backup-Fenster).

Da Datenbestände organisch wachsen, ist eine isolierte Betrachtung des Status quo unzureichend. Eine seriöse Kapazitätsplanung muss zwingend eine präzise Wachstumsprognose für die kommenden Jahre beinhalten. Um den Speicherbedarf und die damit verbundenen Kosten in einem wirtschaftlich vertretbaren Rahmen zu halten, kommen primär zwei technologische Massnahmen zum Einsatz: Deduplizierung und Komprimierung.

Die Deduplizierung ist eine hochentwickelte Methode zur Reduktion des effektiven Backup-Volumens. Hierbei analysiert das Speichersystem den Datenstrom und eliminiert redundante (mehrfach vorkommende) Datenblöcke, sodass jeder Block physisch nur ein einziges Mal gespeichert wird. Die Komprimierung hingegen verkleinert die Dateien durch algorithmische Verfahren, was nicht nur Speicherplatz spart, sondern auch die Übertragungszeiten über das Netzwerk (LAN/WAN) drastisch verkürzt.

Beispiel zur Volumenklassifizierung und Effizienzsteigerung:

Ein international tätiges Architekturbüro generiert täglich hunderte Gigabyte an hochauflösenden CAD-Plänen und 3D-Renderings. Das aktuelle Gesamtvolumen beträgt 50 Terabyte. Die Wachstumsprognose geht von einem Anstieg um 30 Prozent pro Jahr aus. Ohne technologische Hilfsmittel würden die Speicherkosten explodieren. Da CAD-Dateien oft ähnliche strukturelle Metadaten enthalten oder Versionen einer Datei sich nur in Nuancen unterscheiden, kann durch Deduplizierung das zu speichernde Volumen massiv reduziert werden (z. B. auf 20 Terabyte). Dies ermöglicht es dem Unternehmen, den vorhandenen Speicherplatz deutlich länger zu nutzen, bevor teure Hardware-Erweiterungen im Rahmen der Kapazitätsplanung beschafft werden müssen.

4. Vertiefung: Periodizität, Backup-Strategien und das RPO

Die zweite Hauptkategorie bildet die Periodizität. Dieser Begriff beschreibt die regelmässigen, zeitlich festgelegten Abstände, in denen Datensicherungen durchgeführt und systemisch protokolliert werden. Die Periodizität ist kein isolierter Wert, sondern hängt direkt von der Änderungsrate (Change Rate) der Daten ab. Datenbestände, die sich hochfrequent ändern, erfordern zwingend kürzere Backup-Intervalle, um den zuvor definierten RPO-Wert (Recovery Point Objective) einhalten zu können.

Begrenzt wird diese Häufigkeit oft durch das sogenannte Backup-Fenster. Dies ist der definierte Zeitraum (meist in den nachtschlafenden Stunden oder an Wochenenden), in dem Sicherungsjobs durchgeführt werden können, ohne die Performance der produktiven Systeme für die Anwender spürbar zu beeinträchtigen. Für die überwiegende Mehrheit der produktiven Geschäftssysteme gilt eine tägliche Sicherung als das absolute Minimum für einen akzeptablen RPO. Hochkritische Systeme verlangen hingegen oft nach einer kontinuierlichen Sicherung (Continuous Data Protection, CDP), bei der jede Schreibtransaktion in Echtzeit gespiegelt wird.

Um diese Anforderungen technisch abzubilden, stehen verschiedene Backup-Arten zur Verfügung, die oft in einer Hybridstrategie kombiniert werden:

- **Vollsicherung (Full Backup):** Eine komplette Kopie aller Daten zu einem spezifischen Zeitpunkt. Sie bietet die unkomplizierteste Wiederherstellung, benötigt jedoch ein enormes Mass an Speicherplatz und Zeit.
- **Inkrementelles Backup:** Es werden ausschliesslich jene Daten gesichert, die sich seit der *allerletzten* Sicherung (egal ob voll oder inkrementell) geändert haben. Dies ist extrem schnell und platzsparend, macht die Wiederherstellung jedoch komplexer, da die Vollsicherung und alle nachfolgenden Inkremente nacheinander eingespielt werden müssen.
- **Differenzielles Backup:** Hier werden alle Daten gesichert, die sich seit der letzten *Vollsicherung* geändert haben. Der Speicherbedarf wächst mit jedem Tag an, dafür wird für die Wiederherstellung lediglich das Full-Backup und das letzte differenzielle Backup benötigt.
- **Snapshot:** Eine sofortige Momentaufnahme des Systemzustands (oft auf Storage-Ebene). Snapshots ersetzen kein echtes Backup auf ein externes Medium, ermöglichen aber ein sekundenschnelles Zurücksetzen bei logischen Fehlern (z. B. einem fehlerhaften Software-Update).

Die Wahl dieser Backup-Arten und deren Periodizität stehen in direktem Bezug zum Recovery Point Objective (RPO). Das RPO definiert in Zeiteinheiten (Minuten, Stunden, Tage), wie viel Datenverlust das Unternehmen maximal tolerieren kann. Ein System mit einem extrem niedrigen RPO (z. B. 15 Minuten) erfordert hochfrequente Sicherungsmechanismen. Auch hier gilt das Prinzip der Kosten-Nutzen-Abwägung: Kürzere RPO-Werte verursachen überproportional höhere Infrastrukturkosten.

Beispiel zur Periodizität und Backup-Strategie:

Eine Schweizer Kantonalbank betreibt eine zentrale Transaktionsdatenbank. Die Änderungsrate ist tagsüber immens (tausende Buchungen pro Sekunde). Das tolerierte RPO liegt bei null – kein einziger Rappen darf durch einen Systemausfall verloren gehen. Ein tägliches Backup-Fenster in der Nacht ist hier völlig unbrauchbar. Stattdessen nutzt die Bank eine kontinuierliche Sicherung (Echtzeit-Replikation auf ein sekundäres Rechenzentrum).

Im Gegensatz dazu steht das Intranet der Bank, in dem allgemeine Mitarbeiterinformationen als PDF abgelegt werden. Die Änderungsrate ist sehr gering. Hier reicht eine differenzielle Backup-Strategie: Am Wochenende wird eine Vollsicherung durchgeführt, und von Montag bis Freitag jeweils nachts ein differenzielles Backup. Fällt das System am Donnerstag aus, muss der Administrator nur die Vollsicherung vom Sonntag und das differenzielle Backup vom Mittwochabend zurückspielen.

5. Vertiefung: Zugriffssicherheit und Schutzbedarf

Die dritte und in Zeiten von Cyberkriminalität wohl kritischste Hauptkategorie der Klassifizierung ist die Zugriffssicherheit. Der Ausgangspunkt hierfür ist die Bewertung des Schutzbedarfs. Dieser Prozess evaluiert, wie sensibel die vorliegenden Daten sind und welche monetären, rechtlichen oder reputativen Schäden entstehen könnten, falls es zu einem unbefugten Zugriff (Data Breach), einer Manipulation oder einem totalen Verlust kommt.

Daten lassen sich grob in verschiedene Kategorien einteilen, wobei Personendaten (z. B. Gesundheitsakten), Geschäftsgeheimnisse (z. B. Patente, Quellcodes), Finanzdaten und reine operative Daten signifikant unterschiedliche Schutzbedarfsstufen aufweisen. Das Schadenspotenzial korreliert direkt mit dieser Stufe: Je grösser der anzunehmende Schaden bei einer Offenlegung, desto restriktiver und teurer müssen die definierten Sicherheitsmassnahmen sein. Flankiert wird dies durch strenge gesetzliche Vorgaben. In der Schweiz diktiert beispielsweise das revidierte Datenschutzgesetz (revDSG) klare Mindestanforderungen an die technischen und organisatorischen Massnahmen (TOM) zum Schutz besonders schützenswerter Personendaten. Der Einstufungsprozess darf daher niemals allein durch die IT-Abteilung erfolgen, sondern muss zwingend durch die jeweiligen Fachverantwortlichen (Data Owner) in enger Abstimmung mit dem Datenschutzbeauftragten (DPO) und der Compliance-Abteilung vorgenommen werden.

Ist der Schutzbedarf definiert, muss ein rigoroses Berechtigungskonzept für die Backup-Systeme implementiert werden. Backups sind eine hochattraktive Zielscheibe für Angreifer, da sie eine vollständige Kopie der Unternehmenswerte darstellen. Ein rollenbasiertes Zugriffskonzept (RBAC – Role Based Access Control) stellt sicher, dass Nutzer und Systeme nur jene Rechte (z.B. Erstellen, Lesen, Wiederherstellen) erhalten, die sie für ihre spezifische Aufgabe zwingend benötigen. Diese Rechte müssen regelmässig auditiert werden.

Für besonders kritische Aktionen, wie das manuelle Löschen von Backup-Sätzen oder das Ändern von Aufbewahrungsrichtlinien, ist das Vier-Augen-Prinzip unabdingbar. Dies bedeutet, dass eine solche Aktion stets durch einen zweiten, unabhängigen Administrator autorisiert werden muss. Zudem ist eine lückenlose, manipulationssichere Protokollierung (Logging) sämtlicher Zugriffe und Konfigurationsänderungen zwingend erforderlich, um im Rahmen einer forensischen Untersuchung Anomalien schnell detektieren zu können. Schliesslich müssen privilegierte Administratorkonten (Privileged Access) extrem restriktiv gehandhabt, auf ein absolutes Minimum an Personen beschränkt und durch Multi-Faktor-Authentifizierung (MFA) abgesichert werden.

Beispiel zur Zugriffssicherheit:

Ein Forschungsinstitut in Zürich arbeitet an einem geheimen Patent für einen neuen Impfstoff. Der Schutzbedarf dieser Daten ist als "Streng Vertraulich" eingestuft. Ein Ransomware-Angreifer infiltriert das Netzwerk. Moderne Ransomware verschlüsselt nicht nur die Live-Daten, sondern sucht gezielt nach Backup-Servern, um diese vorher zu löschen, damit das Opfer Lösegeld zahlen muss. Weil das Institut das Vier-Augen-Prinzip und rollenbasierte Kontrollen etabliert hat, besitzt der kompromittierte Account des Systemadministrators zwar das Recht, Backups zu erstellen, nicht aber das Recht, diese zu löschen. Ein Löschbefehl würde die Freigabe des IT-Sicherheitsbeauftragten erfordern. Die Backups bleiben somit unangetastet, und das Institut kann die Daten ohne Lösegeldzahlung wiederherstellen.

6. Kryptographie und physische Sicherheit

Die höchsten Schutzbedarfsstufen erfordern technische Massnahmen, die über logische Zugriffskontrollen hinausgehen. Ab einer definierten Schutzklasse greift eine zwingende Verschlüsselungspflicht. Backup-Daten müssen kryptographisch geschützt werden, um auch dann unlesbar zu bleiben, wenn die physischen oder logischen Schutzwälle durchbrochen werden.

Dies unterteilt sich in zwei Bereiche:

1. **Transportverschlüsselung (Data in Transit):** Während die Daten vom produktiven System über das Netzwerk zum Backup-Server fliessen, müssen sie durch starke Verschlüsselungsprotokolle (wie TLS 1.3) geschützt sein, um Man-in-the-Middle-Angriffe oder das Abhören von Datenpaketen (Sniffing) zu verhindern.
2. **Ruheverschlüsselung (Data at Rest):** Sobald die Daten auf dem Speichermedium (Festplatte, Tape, Cloud) abgelegt sind, müssen sie verschlüsselt sein. Dies schützt vor unbefugtem Zugriff, falls beispielsweise eine Festplatte physisch aus dem Rechenzentrum entwendet wird.

Hierbei muss anerkannt, zertifizierten Standards wie dem Advanced Encryption Standard mit einer Schlüssellänge von 256 Bit (AES-256) der Vorzug gegeben werden. Ein oft unterschätzter Aspekt ist dabei das Schlüsselmanagement (Key Management). Die Verschlüsselungsschlüssel dürfen unter keinen Umständen am selben Ort wie die Backup-Daten selbst aufbewahrt werden. Ein strikt getrenntes System (z.B. ein Hardware Security Module - HSM) ist hierfür Best Practice. Geht der Schlüssel verloren, ist das Backup unwiederbringlich zerstört – eine Tatsache, die das Schlüsselmanagement zur kritischsten Komponente der Kryptographie macht.

Die sicherste Verschlüsselung ist jedoch wirkungslos, wenn die physische Sicherheit vernachlässigt wird. Backup-Medien und die dazugehörigen Server müssen in speziell gesicherten Brandabschnitten gelagert werden, die durch biometrische Zutrittskontrollen, Videoüberwachung und moderne Brandunterdrückungssysteme geschützt sind.

Um das Risiko eines lokalen Totalverlusts (beispielsweise durch einen Grossbrand, ein Erdbeben oder einen gezielten Sabotageakt im Hauptrechenzentrum) zu mitigieren, ist die Offsite-Lagerung essenziell. Backups (oft auf Magnetbändern) werden dabei physisch in ein externes, geografisch getrenntes Lager verbracht. Der Transport dieser Medien darf nicht unkontrolliert erfolgen. Er muss durch spezialisierte Sicherheitsdienstleister in gepanzerten oder zumindest verschlossenen Fahrzeugen und unter Führung einer lückenlosen Übergabedokumentation (Chain of Custody) stattfinden.

Erreichen physische Datenträger ihr Lebensende (End-of-Life), greift der Prozess der Medienvernichtung. Ausgemusterte Bänder oder Festplatten dürfen nicht einfach entsorgt werden. Sie müssen durch zertifizierte Prozesse physisch geschreddert oder durch Entmagnetisierung (Degaussing) so zerstört werden, dass eine forensische Datenrekonstruktion mathematisch und physikalisch ausgeschlossen ist.

Beispiel zur physischen Sicherheit und Verschlüsselung:

Eine kantonale Steuerverwaltung sichert jede Nacht die Steuererklärungen sämtlicher Einwohner auf Magnetbänder. Diese Bänder werden am nächsten Morgen von einem Sicherheitskurier in einen Bunker in den Schweizer Alpen (Offsite-Lagerung) transportiert. Sollte das Fahrzeug des Kuriers auf dem Weg in einen Unfall verwickelt werden und ein Band in falsche Hände geraten, ist dies kein Datenschutzvorfall, der meldepflichtig wäre. Warum? Weil die Daten mit AES-256 (Ruheverschlüsselung) verschlüsselt sind und der Schlüssel sicher in einem HSM im Rechenzentrum liegt. Das Band ist für den Dieb völlig wertlos und stellt nur eine Ansammlung von zufälligem Rauschen dar.

7. Fazit

Zusammenfassend lässt sich festhalten, dass die Datenklassifizierung gemäss den dargelegten Prinzipien weit mehr ist als eine administrative Fleissaufgabe. Sie ist das architektonische Fundament, auf dem die gesamte Informationssicherheit und Ausfallsicherheit eines Unternehmens ruht. Die präzise Einteilung nach Volumen und Periodizität ermöglicht den effizienten, ressourcenschonenden und zielgerichteten Einsatz von Speichertechnologien. Sie garantiert, dass in Notfallszenarien die richtigen Daten zur richtigen Zeit wiederhergestellt werden können, wodurch die Überlebensfähigkeit der kritischen Geschäftsprozesse (gemessen in RTO und RPO) sichergestellt wird.

Gleichzeitig bildet die Klassifizierung nach Zugriffssicherheit, gepaart mit starken kryptographischen und physischen Massnahmen, den essenziellen Schutzschild gegen eine zunehmend aggressive globale Bedrohungslandschaft durch Cyberkriminalität und Spionage. Nur wenn Unternehmen den exakten Wert, die Relevanz und den Schutzbedarf jedes einzelnen Bytes in ihrer Infrastruktur kennen, können sie die Vertraulichkeit, Integrität und Verfügbarkeit (das CIA-Triad) ihrer wertvollsten Ressource in der digitalen Ära garantieren. Die Methodik erfordert eine stetige interdisziplinäre Zusammenarbeit zwischen IT, Fachbereichen, Geschäftsleitung und Compliance – ein Aufwand, der angesichts der existenziellen Risiken eines Datenverlusts alternativlos ist.

8. Quellenverzeichnis

1. Polat, Mevluet. *Datenklassifizierung II – Vertiefung*. Präsentationsfolien (Folie 2 - 13). [Unveröffentlichtes Lehrmaterial/Präsentation].
2. Bundesversammlung der Schweizerischen Eidgenossenschaft. *Bundesgesetz über den Datenschutz (Datenschutzgesetz, DSG)*. SR 235.1. Stand: revidierte Fassung.
3. BSI – Bundesamt für Sicherheit in der Informationstechnik. *IT-Grundschutz-Kompendium: Baustein CON.3 Datensicherungskonzept*.
4. NIST – National Institute of Standards and Technology. *Special Publication 800-111: Guide to Storage Encryption Technologies for End User Devices*.
5. ITIL® 4 Foundation (IT Service Management). Kapitel zum *IT Service Continuity Management* und *Capacity and Performance Management*. AXELOS.